

OWASP Top 10: 2021 → 2025

Transition Reference Card · What changed, what moved, what is new
Secure Web Application Development · BBC Academy / JBI Training · 19–20 March 2026

Unchanged — same position and name	Moved up — higher risk ranking in 2025	Moved down — lower risk ranking in 2025
Renamed / reframed — same position, broader scope	NEW in 2025 — no direct 2021 equivalent	Removed from Top 10 — absorbed into another category

2021	OWASP Top 10:2021 Category		2025	OWASP Top 10:2025 Category	Change Summary & Course Notes
A01	Broken Access Control	→	A01	Broken Access Control → No change	Remains the most prevalent web application risk. Covers IDOR, missing function-level access control, forced browsing, and privilege escalation. All 2021 guidance still applies. Course: Module 6
A05	Security Misconfiguration	→	A02	Security Misconfiguration ▲ Moved up 3	Rises sharply in 2025, reflecting the explosion of cloud and containerised deployments where default credentials, exposed debug endpoints, and permissive CORS are endemic. Scope unchanged. Course: Module 7
A06	Vulnerable and Outdated Components	→	A03	Software Supply Chain Failures ▲ Moved up 3 + Renamed	Significantly broadened in 2025. Now encompasses dependency confusion attacks, compromised build pipelines, malicious packages (e.g. XZ Utils backdoor), and SBOMs. The old "outdated components" framing was too narrow. Course: Module 7
A02	Cryptographic Failures	→	A04	Cryptographic Failures ▼ Moved down 2	Scope unchanged: weak algorithms, hardcoded secrets, broken TLS, and sensitive data in transit/at rest. Slight fall in ranking reflects improved adoption of TLS 1.3 and secrets management tooling. Course: Module 8
A03	Injection (incl. XSS)	→	A05	Injection (incl. XSS + SSRF) ▼ Moved down 2 + SSRF absorbed	SQLi, Command Injection, XSS all remain. Crucially, SSRF (formerly A10:2021) is now treated as a type of injection rather than a standalone category. Content and exercises unchanged. Course: Module 9
A04	Insecure Design	→	A06	Insecure Design ▼ Moved down 2	Scope unchanged: absence of threat modelling, insecure architecture decisions, and missing security controls in design. Slight ranking drop does not diminish its importance in the SSDLC. Course: Module 10
A07	ID & Authentication Failures	→	A07	ID & Authentication Failures → No change	Unchanged in position and scope. Covers broken authentication, weak credential policies, missing MFA, session fixation, and credential stuffing. All

2021	OWASP Top 10:2021 Category		2025	OWASP Top 10:2025 Category	Change Summary & Course Notes
					ShopCo and Juice Shop exercises directly apply. Course: Module 6
A08	Software & Data Integrity Failures	→	A08	Software & Data Integrity Failures → <i>No change</i>	Unchanged. Covers insecure deserialization, unsigned CI/CD pipelines, auto-update mechanisms without integrity verification, and client-side data tampering. Juice Shop score/price manipulation exercises apply directly. Course: Module 8
A09	Security Logging & Monitoring Failures	→	A09	Logging & Alerting Failures → <i>Renamed (same position)</i>	"Alerting" replaces "Monitoring" in the name — a deliberate shift emphasising that logs are only valuable if they trigger timely alerts. The addition of "alerting" reflects SOC/SIEM integration expectations in 2025. Course: Module 11
—	(not in 2021)	→	A10	Mishandling of Exceptional Conditions ★ <i>New category (SSRF → A05)</i>	SSRF exits as a standalone entry (absorbed into A05 Injection). The new A10 addresses improper error handling, stack trace disclosure, unhandled exceptions used as attack vectors, and fail-open security logic. Course: Module 10

The Two Genuinely New Things in OWASP Top 10:2025

1. A03 Software Supply Chain Failures replaces the narrower "Vulnerable and Outdated Components" framing. This is not just a rename — it adds an entirely new threat model: compromised build pipelines, malicious upstream packages, and SBOMs (Software Bill of Materials). The XZ Utils backdoor (2024) is the canonical real-world example.
2. A10 Mishandling of Exceptional Conditions is a brand-new category with no 2021 equivalent. It covers improper error handling, information disclosure via stack traces, and fail-open logic where an exception bypasses security checks.

What Happened to SSRF?

Server-Side Request Forgery (A10:2021) has been absorbed into A05 Injection in 2025. The reasoning: SSRF is fundamentally an injection vulnerability where untrusted data (a URL) is interpreted as a command (a server-side fetch). The defensive principle — never let user input directly specify what the server fetches — is identical to the injection principle of never letting user input become code. SSRF content is covered in Module 9 (Injection) in this course. The practical exercises using Juice Shop and the SSRF Anatomy reference card are unchanged.

M6 (Day 1) A01 + A07	M7 (Day 2) A02 + A03	M8 (Day 2) A04 + A08	M9 (Day 2) A05	M10 (Day 2) A06 + A10	M11 (Day 2) A09
-------------------------	-------------------------	-------------------------	-------------------	--------------------------	--------------------